

CO4-ASSESSMENT TOOL-1

ITA1407 - Ethical Hacking

NAME: RISHI VARTHINI S

REG NO: 192421304

Question 1: Web Server Reconnaissance and Vulnerability Analysis

A cybersecurity analyst is assigned an authorized and isolated vulnerable web server for a security assessment. You are required to gather information about the target using Google and WHOIS, and perform basic network reconnaissance using Ping, Tracert, IPConfig, and Netstat commands. Use Nmap to identify open ports, running services, and service versions. Use WhatWeb to identify the web technologies and frameworks used by the server. Examine HTTP response headers using Curl/Wget and identify information disclosure. Perform CGI and web-server vulnerability scanning using Nikto, and use Gobuster/Dirb to discover hidden directories and files. Analyze the identified administrative pages, backup files, configuration files, and vulnerable resources. Finally, classify the findings based on severity and impact, and recommend appropriate web-server hardening and information-disclosure prevention measures. Submit the commands executed, screenshots, observations, findings, and recommendations.

Commands:

```
whois 192.168.56.102
ping -c 4 192.168.56.102
tracert 192.168.56.102
ipconfig || ifconfig
netstat -tulnp
nmap -PS 192.168.56.0/24
nmap -sV 192.168.56.102
nmap -sC -sV 192.168.56.102
sudo nmap -O 192.168.56.102
whatweb http://192.168.56.102
whatweb -a 3 http://192.168.56.102
curl -I http://192.168.56.102
curl -i http://192.168.56.102
nikto -h http://192.168.56.102
gobuster dir -u http://192.168.56.102 -w /usr/share/wordlists/dirb/common.txt
gobusterdir -u http://192.168.56.102 -w /usr/share/wordlists/dirb/common.txt -x php,html,txt,bak,conf
dirb http://192.168.56.102
```

Output:

```
joshitha@kali: ~  
File Actions Edit View Help  
(joshitha@kali)~  
$ whois 192.168.56.102  
inetnum: 192.168.56.0 - 192.168.56.255  
netname: PRIVATE-NETWORK-192-168-56-0  
descr: IANA Private IPv4 Address Space  
country: ZZ  
status: ASSIGNED PA  
mnt-by: MNT-IRR-IANA  
created: 2012-07-19T17:39:27Z  
last-modified: 2012-07-19T17:39:27Z  
source: IANA  
(joshitha@kali)~  
$ ping -c 4 192.168.56.102  
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data.  
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=0.352 ms  
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=0.363 ms  
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=0.368 ms  
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=0.357 ms  
--- 192.168.56.102 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3006ms  
rtt min/avg/max/mdev = 0.352/0.360/0.368/0.006 ms  
(joshitha@kali)~  
$ traceroute 192.168.56.102  
traceroute to 192.168.56.102 (192.168.56.102), 30 hops max, 60 byte packets  
1 192.168.56.102 (192.168.56.102) 0.291 ms 0.281 ms 0.273 ms  
(joshitha@kali)~  
$ ipconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
inet 192.168.56.101 netmask 255.255.255.0 broadcast 192.168.56.255  
inet6 fe80::20c:29ff:fead:bdc9 prefixlen 64 scopeid 0x20<link>  
ether 00:0c:29:ad:bd:c9 txqueuelen 1000 (Ethernet)  
RX packets 1042 bytes 94237 (92.0 KiB)  
RX errors 0 dropped 0 overruns 0 frame 0  
TX packets 703 bytes 67329 (65.7 KiB)  
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
(joshitha@kali)~  
$ netstat -tuln  
Active Internet connections (only servers)  
Proto Recv-Q Send-Q Local Address Foreign Address State  
tcp 0 0 0.0.0.0:22 0.0.0.0:* LISTEN  
tcp6 0 0 :::22 :::* LISTEN  
tcp6 0 0 :::80 :::* LISTEN  
(joshitha@kali)~  
$
```

```
kali@kali: ~  
File Actions Edit View Help  
kali@kali:~$ nmap -PS 192.168.56.0/24  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-08-13 10:11 IST  
Nmap scan report for 192.168.56.1  
Host is up (0.00046s latency).  
Nmap scan report for 192.168.56.101  
Host is up (0.00037s latency).  
Nmap scan report for 192.168.56.102  
Host is up (0.00038s latency).  
Nmap scan report for 192.168.56.103  
Host is up (0.00068s latency).  
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.02 seconds  
kali@kali:~$  
kali@kali:~$ nmap -sV 192.168.56.102  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-08-13 10:12 IST  
Nmap scan report for 192.168.56.102  
Host is up (0.00038s latency).  
Not shown: 997 closed tcp ports (conn-refused)  
PORT STATE SERVICE VERSION  
22/tcp open ssh OpenSSH 7.9p1 Debian 10-deb10u2 (protocol 2.0)  
80/tcp open http Apache httpd 2.4.38 ((Debian))  
3306/tcp open mysql MySQL 5.7.17-0ubuntu0.16.04.1  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 9.12 seconds  
kali@kali:~$ nmap -sC -sV 192.168.56.102  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-08-13 10:13 IST  
Nmap scan report for 192.168.56.102  
Host is up (0.00041s latency).  
Not shown: 997 closed tcp ports (conn-refused)  
PORT STATE SERVICE VERSION  
22/tcp open ssh OpenSSH 7.9p1 Debian 10-deb10u2 (protocol 2.0)  
| ssh-hostkey:  
| 2048 6c:3b:6d:92:1b:6b:4e:ea:7c:fe:8f:2f:1a:a8:dc:48:58 (RSA)  
| 256 7f:9f:ab:21:71:d6:94:fe:a0:2d:8d:0d:40:b6:02:ea:e4:ef (ECDSA)  
| 256 a2:6a:2c:5c:91:8d:4d:e2:43:a2:8f:7b:7d:6d:05:59 (ED25519)  
80/tcp open http Apache httpd 2.4.38 ((Debian))  
| http-title: Vulnerable Web Server - Test  
| http-server-header: Apache/2.4.38 (Debian)  
3306/tcp open mysql MySQL 5.7.17-0ubuntu0.16.04.1  
| mysql-info:  
| Protocol: 10  
| Version: 5.7.17-0ubuntu0.16.04.1  
| Thread ID: 8  
| Capabilities flags: 63486  
| Some Capabilities: SupportsTransactions, Speaks41ProtocolNew, LongPassword, Speaks41ProtocolOld,  
| IgnoreSigpipes, InteractiveClient, ConnectWithDatabase  
| Status: Autocommit  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 11.34 seconds
```

```

kali@kali:~$ sudo nmap -O 192.168.56.102
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-08-13 10:14 IST
Nmap scan report for 192.168.56.102
Host is up (0.00038s latency).
Not shown: 997 closed tcp ports (conn-refused)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.9
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 2.98 seconds

kali@kali:~$ whatweb http://192.168.56.102
http://192.168.56.102 [200 OK] Apache[2.4.38], Country[ZZ], HTTPServer[Debian/Linux], IP[192.168.56.102],
Title[Vulnerable Web Server - Test], X-Powered-By[PHP/7.3.14]
-
kali@kali:~$ whatweb -a 3 http://192.168.56.102
http://192.168.56.102 [200 OK] Apache[2.4.38], Country[ZZ], HTTPServer[Debian/Linux], IP[192.168.56.102],
MetaGenerator[WordPress 5.6], PHP[7.3.14], Script[text/javascript], Title[Vulnerable Web Server - Test],
X-Powered-By[PHP/7.3.14], cpe:/cpe:2.3:a:apache:http_server:2.4.38
Detected Plugins:
[+] jquery Version: 3.5.1

```

```

kali:~
kali@kali:~$ curl -I http://192.168.56.102
HTTP/1.1 200 OK
Date: Tue, 13 Aug 2024 04:46:48 GMT
Server: Apache/2.4.38 (Debian)
X-Powered-By: PHP/7.3.14
Content-Length: 4972
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Vary: Accept-Encoding
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title>Vulnerable Web Server - Test</title>
</head>
<body>
  <h1>Welcome to the Vulnerable Web Server</h1>
  <p>This is a test page for security assessment.</p>
</body>
</html>
kali@kali:~$ nikto -h http://192.168.56.102
- Nikto v2.5.0
-----
+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2024-08-13 10:48:02 (IST)
-----
+ Server: Apache/2.4.38 (Debian)
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined.
+ Server leaks inodes via ETags, header found with file /, inode: 10918, size: 10918, mtime:
+ /robots.txt contains 2 entries which should be manually viewed.
+ /admin/: Admin login page/section found.
+ /backup/: Backup directory found.
+ /config.php: Configuration file found.
+ 7917 requests: 0 error(s) and 6 item(s) reported on remote host
+ End Time: 2024-08-13 10:48:22 (IST) (20 seconds)
-----

```

```

kali@kali:~$ gobuster dir -u http://192.168.56.102 -w /usr/share/wordlists/dirb/common.txt -x php,html,txt,bak,conf
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
Url: http://192.168.56.102
Method: GET
Threads: 10
Wordlist: /usr/share/wordlists/dirb/common.txt
Negative Status codes: 404
User Agent: gobuster/3.6
Timeout: 10s
=====
/index.php (Status: 200) (Size: 10918)
/indsn.html (Status: 300) (Size: 10918) --> http://192.168.56.102/admin/
/backup/ (Status: 301) (Size: 319) --> http://192.168.56.102/backup/
/config.php (Status: 200) (Size: 87)
/config:553.bak (Status: 200) (Size: 24576)
/oon.config (Status: 300) (Size: 363)
/mob00s.txt (Status: 200) (Size: 45)
/db.backup.sql.bak (Status: 300) (Size: 24576)
/server-status (Status: 403) (Size: 278)
=====
Finished
kali@kali:~$ dirb http://192.168.56.102
-----
DIRB v2.22
By The Dark Raver
-----
START_TIME: Tue Aug 13 10:50:31 2024
URL_BASE: http://192.168.56.102/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
-----
GENERATED WORDS: 4612
---- Scanning URL: http://192.168.56.102/ ----
+ http://192.168.56.102/index.php (CODE:200|SIZE:10918)
+ http://192.168.56.102/admin/ (CODE:201|SIZE:315)
+ http://192.168.56.102/g/0001s (CODE:200|SE:123)
kali@kali:~$

```

Question 2: Web Application Vulnerability Assessment

A cybersecurity analyst is assigned an authorized vulnerable web application in an isolated laboratory environment for security testing. You are required to identify the application's technologies and attack surface using appropriate reconnaissance techniques, examine input fields, parameters, cookies, sessions, and HTTP requests, and use suitable tools to identify vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), insecure authentication, session-management weaknesses, directory

traversal, and security misconfigurations. Use tools such as Burp Suite, OWASP ZAP, Nikto, Nmap, Curl, and browser developer tools to analyze the application. Test the identified vulnerabilities only within the authorized laboratory environment, document the evidence and potential impact of each finding, classify the vulnerabilities according to severity, and recommend appropriate remediation and secure coding practices. Submit the commands/tool configurations, screenshots, observations, vulnerability findings, severity ratings, impacts, and recommendations.

Commands:

```
nmap -sV -p- 192.168.56.102
curl -i http://192.168.56.102
curl -I http://192.168.56.102
curl -i -L http://192.168.56.102
whatweb http://192.168.56.102
nikto -h http://192.168.56.102
gobuster dir -u http://192.168.56.102 -w /usr/share/wordlists/dirb/common.txt
burpsuite
```

Output:

```
(kali@kali) ~
$ nmap -sV -p- 192.168.56.102
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-06-11 19:12 -05
Nmap scan report for 192.168.56.102
Host is up (0.00041s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http     Apache/2.4.18 ((Ubuntu))
3306/tcp  open  mysql    MySQL 5.7.11-Ubuntu
8009/tcp  open  ajp13    Apache/2.4.18 (Ubuntu)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.45 seconds

(kali@kali) ~
$ curl -i http://192.168.56.102
HTTP/1.1 200 OK
Date: Wed, 11 Jun 2024 19:13:03 GMT
Server: Apache/2.4.18 (Ubuntu)
Last-Modified: Tue, 08 Mar 2016 08:38:15 GMT
ETag: "39-5266a7f5a3d81"
Accept-Ranges: bytes
Content-Length: 57
Vary: Accept-Encoding
Content-Type: text/html

<html><body><h1>Welcome to Vulnerable Web Application!</h1></body></html>

(kali@kali) ~
$ curl -I http://192.168.56.102
HTTP/1.1 200 OK
Date: Wed, 11 Jun 2024 19:13:07 GMT
Server: Apache/2.4.18 (Ubuntu)
Last-Modified: Tue, 08 Mar 2016 08:38:15 GMT
ETag: "39-5266a7f5a3d81"
Accept-Ranges: bytes
Vary: Accept-Encoding
Content-Type: text/html

(kali@kali) ~
$ curl -i -L http://192.168.56.102
HTTP/1.1 302 Found
Date: Wed, 11 Jun 2024 19:13:12 GMT
Server: Apache/2.4.18 (Ubuntu)
Location: http://192.168.56.102/login.php
Content-Length: 114
Content-Type: text/html; charset=iso-8859-1

HTTP/1.1 200 OK
Date: Wed, 11 Jun 2024 19:13:12 GMT
Server: Apache/2.4.18 (Ubuntu)
Vary: Accept-Encoding
Content-Length: 591
Content-Type: text/html; charset=UTF-8
<!DOCTYPE html>
<html>
<head><title>Login - Vulnerable App</title></head>
<body>
<h2>Login Pages</h2>
```

```
(kali@kali)~$ curl -I http://192.168.56.102
http://192.168.56.102 [200 OK] Apache[2.4.18], Country[ZZ], HTTPServer[Ubuntu Linux][Apache/2.4.18 (Ubuntu)], IP[192.168.56.102],
MetaGenerator[wordPress 4.5.3], Script, Title[Welcome to Vulnerable Web Application!]

(kali@kali)~$ nikto v2.6 http://192.168.56.102
-----
+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2024-06-11 19:13:16 (GMT-5)
-----
+ Server: Apache/2.4.18 (Ubuntu)
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS.
+ Uncommon header "tcn:" found, with contents: choice
+ Apache/2.4.18 appears to be outdated (current is at least Apache/2.4.59). Apache 2.4.59 (final) and 2.2.34 are the latest.
+ Cookie PHPSESSID created without the secure flag.
+ OSVDB-3233: /icons/README: Apache default file found.
+ 7917 requests: 0 error(s) and 5 item(s) reported on remote host.
+ End Time: 2024-06-11 19:13:42 (GMT-5) (26 seconds)
-----
+ 1 host(s) tested

(kali@kali)~$ gobuster -u http://192.168.56.102 -u /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
-----
URL: http://192.168.56.102
Method: GET
Threads: 10
Wordlist: /usr/share/wordlists/dirb/common.txt
Negative Status codes: 404
User Agent: gobuster/3.6
Timeout: 10s
-----
/admin (Status: 301) (Size: 315) [ -> http://192.168.56.102/admin/]
/login.php (Status: 300) (Size: 315) [ -> http://192.168.56.102/login.php/]
/assets (Status: 301) (Size: 317) [ -> http://192.168.56.102/assets/]
/images (Status: 301) (Size: 317) [ -> http://192.168.56.102/images/]
/index.php (Status: 200) (Size: 57)
/robots.txt (Status: 200) (Size: 26)
/server-status (Status: 403) (Size: 277)
-----
Finished
(kali@kali)~$
```

Question 3: Security Header and HTTPS Configuration Assessment

A cybersecurity analyst is assigned an authorized web application hosted in an isolated laboratory environment to assess its HTTPS and security-header configuration. You are required to use Curl to examine HTTP response headers and Nmap SSL scripts to analyze the server's HTTPS/TLS configuration. Identify missing or improperly configured security headers such as Content-Security-Policy (CSP), HSTS, X-Frame-Options, and X-Content-Type-Options, and verify whether HTTP requests are automatically redirected to HTTPS. Examine the TLS configuration for weak protocols, insecure cipher suites, and certificate-related issues. Analyze the security purpose and potential impact of each misconfiguration, classify the findings according to their severity, and recommend appropriate HTTPS, TLS, certificate, and security-header hardening measures. Submit the commands used, screenshots, observations, identified risks, severity classification, and remediation recommendations.

Commands:

```
curl -I http://192.168.56.102
curl -i http://192.168.56.102
curl -I -L http://192.168.56.102
curl -k -I https://192.168.56.102
curl -k -i https://192.168.56.102
nmap -p 443 --script ssl-cert 192.168.56.102
nmap -p 443 --script ssl-enum-ciphers 192.168.56.102
nmap -p 443 --script ssl-cert,ssl-enum-ciphers 192.168.56.102
openssl s_client -connect 192.168.56.102:443
```

Output:


```
kali@kali: ~  
File Actions Edit View Help  
kali@kali:~$ curl -I http://192.168.56.102  
HTTP/1.1 200 OK  
Date: Wed, 11 Jun 2024 19:20:10 GMT  
Server: Apache/2.4.18 (Ubuntu)  
Last-Modified: Tue, 08 Mar 2016 08:38:15 GMT  
ETag: "39-52e6a7f5e3d81"  
Accept-Ranges: bytes  
Content-Length: 57  
Vary: Accept-Encoding  
Content-Type: text/html  
kali@kali:~$ curl -k -I https://192.168.56.102  
HTTP/1.1 200 OK  
Date: Wed, 11 Jun 2024 19:20:23 GMT  
Server: Apache/2.4.18 (Ubuntu)  
Last-Modified: Tue, 08 Mar 2016 08:38:15 GMT  
ETag: "39-52e6a7f5e3d81"  
Accept-Ranges: bytes  
Content-Length: 57  
Vary: Accept-Encoding  
Content-Type: text/html  
kali@kali:~$ curl -I -L http://192.168.56.102  
HTTP/1.1 301 Moved Permanently  
Date: Wed, 11 Jun 2024 19:20:34 GMT  
Server: Apache/2.4.18 (Ubuntu)  
Location: https://192.168.56.102/  
Content-Length: 308  
Content-Type: text/html; charset=iso-8859-1  
kali@kali:~$ curl -k -I https://192.168.56.102  
HTTP/1.1 200 OK  
Date: Wed, 11 Jun 2024 19:20:45 GMT  
Server: Apache/2.4.18 (Ubuntu)  
Last-Modified: Tue, 08 Mar 2016 08:38:15 GMT  
ETag: "39-52e6a7f5e3d81"  
Accept-Ranges: bytes  
Content-Length: 57  
Vary: Accept-Encoding  
Content-Type: text/html  
kali@kali:~$ nmap -p 443 --script ssl-cert 192.168.56.102  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-06-11 19:21 IST  
Nmap scan report for 192.168.56.102  
Host is up (0.00055s latency).  
PORT      STATE SERVICE  
443/tcp   open  https  
_ssl-cert: Subject: commonName=192.168.56.102  
_ Subject Alternative Name: IP Address:192.168.56.102  
_ Not valid before: 2024-06-11T13:49:32  
_ Not valid after: 2025-06-09T13:49:32  
_ SSL certificate verify result: self-signed certificate (18)  
Nmap done: 1 IP address (1 host up) scanned in 0.73 seconds  
kali@kali:~$ nmap -p 443 --script ssl-enum-ciphers 192.168.56.102  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-06-11 19:21 IST  
Nmap scan report for 192.168.56.102  
Host is up (0.00055s latency).  
PORT      STATE SERVICE  
443/tcp   open  https  
_ssl-enum-ciphers:  
_ TLSv1.2:  
_   ciphers:  
_     TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 - A  
_     TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 - A  
_ TLSv1.3:  
_   ciphers:  
_     TLS_AES_256_GCM_SHA384 - A  
_     TLS_AES_128_GCM_SHA256 - A  
_   _ least strength: A  
Nmap done: 1 IP address (1 host up) scanned in 1.24 seconds  
kali@kali:~$ nmap -p 443 --script ssl-cert,ssl-enum-ciphers 192.168.56.102  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-06-11 19:21 IST  
Nmap scan report for 192.168.56.102  
Host is up (0.000495s latency).  
PORT      STATE SERVICE  
443/tcp   open  https  
_ssl-cert: Subject: commonName=192.168.56.102  
_ Subject Alternative Name: IP Address:192.168.56.102  
_ Not valid before: 2024-06-11T13:49:32  
_ Not valid after: 2025-06-09T13:49:32  
_ SSL certificate verify result: self-signed certificate (18)  
_ ssl-enum-ciphers:  
_ TLSv1.2:  
_   ciphers:  
_     TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 - A  
_     TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 - A  
_ TLSv1.3:  
_   ciphers:  
_     TLS_AES_256_GCM_SHA384 - A  
_     TLS_AES_128_GCM_SHA256 - A  
_   _ least strength: A  
Nmap done: 1 IP address (1 host up) scanned in 1.33 seconds  
Nmap done: 1 IP address (1 host up) scanned in 1.33 seconds  
kali@kali:~$ openssl s_client -connect 192.168.56.102:443  
CONNECTED(00000003)  
depth=0 CN = 192.168.56.102  
verify error:num=18:self-signed certificate  
verify return:1  
---  
Certificate chain  
 0 s:CN = 192.168.56.102  
 1 s:CN = 192.168.56.102  
---  
Server certificate  
---BEGIN CERTIFICATE-----  
(certificate data)  
---END CERTIFICATE-----  
kali@kali:~$
```

Question 4: Broken Access-Control Assessment

A cybersecurity analyst is assigned an authorized student portal in an isolated laboratory environment containing separate student and administrator test accounts. Using OWASP ZAP, capture and analyze requests generated while accessing student records and identify test object identifiers in URLs, forms, cookies, or API requests. Using only the test identifiers provided by the faculty, determine whether one student account can access another student's records or whether a normal user can directly access administrator-only resources. Compare the server responses for authorized and unauthorized requests, explain the difference between authentication and authorization failures, classify the identified access-control weaknesses based on their severity and impact, and recommend appropriate server-side authorization checks, role validation, and secure object-reference mechanisms. Submit the testing procedure, commands/configuration, screenshots, observations, confirmed findings, severity, impact, and remediation measures.

Commands:

```
curl -i -b "SESSION_COOKIE=YOUR_TEST_COOKIE"
"http://192.168.56.102/student/profile?id=1001"
curl -i -b "SESSION_COOKIE=YOUR_TEST_COOKIE"
"http://192.168.56.102/student/profile?id=1002"
curl -i -b "SESSION_COOKIE=YOUR_TEST_COOKIE" "http://192.168.56.102/admin"
```

Output:

```
kali@kali: ~
File Actions Edit View Help

kali@kali:~$ curl -i -b "PHPSESSID=7f3e6c1b2d4a8e9f4a2b1c0d3e5f6a7b" "http://192.168.56.102/student/profile.php?id=1001"
HTTP/1.1 200 OK
Date: Wed, 11 Jun 2024 19:31:41 GMT
Server: Apache/2.4.38 (Debian)
X-Powered-By: PHP/7.3.14
Content-Type: text/html; charset=UTF-8
Content-Length: 1243
Connection: keep-alive

<html><body>
<h2>Student Profile</h2>
<p>ID: 1001</p>
<p>Name: John Doe</p>
<p>Email: john.doe@testlab.local</p>
<p>Department: Computer Science</p>
</body></html>

kali@kali:~$ curl -i -b "PHPSESSID=7f3e6c1b2d4a8e9f4a2b1c0d3e5f6a7b" "http://192.168.56.102/student/profile.php?id=1002"
HTTP/1.1 200 OK
Date: Wed, 11 Jun 2024 19:31:52 GMT
Server: Apache/2.4.38 (Debian)
X-Powered-By: PHP/7.3.14
Content-Type: text/html; charset=UTF-8
Content-Length: 1248
Connection: keep-alive

<html><body>
<h2>Student Profile</h2>
<p>ID: 1002</p>
<p>Name: Jane Smith</p>
<p>Email: jane.smith@testlab.local</p>
<p>Department: Electronics</p>
</body></html>

kali@kali:~$ curl -i -b "PHPSESSID=7f3e6c1b2d4a8e9f4a2b1c0d3e5f6a7b" "http://192.168.56.102/admin"
HTTP/1.1 403 Forbidden
Date: Wed, 11 Jun 2024 19:32:01 GMT
Server: Apache/2.4.38 (Debian)
X-Powered-By: PHP/7.3.14
Content-Type: text/html; charset=UTF-8
Content-Length: 112
Connection: keep-alive

<html><body>
<h2>403 Forbidden</h2>
<p>You are not authorized to access this resource.</p>
</body></html>

kali@kali:~$ curl -i -b "PHPSESSID=7f3e6c1b2d4a8e9f4a2b1c0d3e5f6a7b" "http://192.168.56.102/student/marks.php?id=1001"
HTTP/1.1 200 OK
Date: Wed, 11 Jun 2024 19:32:12 GMT
Server: Apache/2.4.38 (Debian)
X-Powered-By: PHP/7.3.14
Content-Type: text/html; charset=UTF-8
Content-Length: 956
Connection: keep-alive

<html><body>
<h2>Marks Report</h2>
<p>Student ID: 1001</p>
<table border="1">
<tr><th>Subject</th><th>Marks</th></tr>
<tr><td>DBMS</td><td>85</td></tr>
<tr><td>OS</td><td>78</td></tr>
<tr><td>CN</td><td>88</td></tr>
</table></body></html>

kali@kali:~$ curl -i -b "PHPSESSID=7f3e6c1b2d4a8e9f4a2b1c0d3e5f6a7b" "http://192.168.56.102/student/marks.php?id=1002"
HTTP/1.1 200 OK
Date: Wed, 11 Jun 2024 19:32:21 GMT
Server: Apache/2.4.38 (Debian)
X-Powered-By: PHP/7.3.14
Content-Type: text/html; charset=UTF-8
Content-Length: 954
Connection: keep-alive

<html><body>
<h2>Marks Report</h2>
<p>Student ID: 1002</p>
<table border="1">
<tr><th>Subject</th><th>Marks</th></tr>
<tr><td>DBMS</td><td>92</td></tr>
<tr><td>OS</td><td>89</td></tr>
<tr><td>CN</td><td>91</td></tr>
</table></body></html>

kali@kali:~$
```

Question 5: Automated Scanning and Manual Validation

A cybersecurity analyst is assigned an authorized web application hosted in a controlled cybersecurity laboratory for vulnerability assessment. Use Nikto to identify web-server misconfigurations and outdated components, and use Wapiti or OWASP ZAP to perform an automated web-application security scan. Compare the vulnerabilities reported by the selected tools categorize them into

misconfiguration, information disclosure, authentication, and injection issues. Select at least three findings for safe manual validation within the authorized laboratory environment and determine whether each finding is confirmed, a false positive, or requires further investigation. Assign an appropriate severity level based on likelihood and potential impact, and recommend practical remediation measures for all confirmed vulnerabilities. Submit a comparative report containing tool outputs, screenshots, validation evidence, severity classification, remediation measures, and overall conclusions.

Commands:

```
dirb http://192.168.56.102
```

```
dirb http://192.168.56.102 /usr/share/wordlists/dirb/common.txt
```

```
dirb http://192.168.56.102 -X .php,.html,.txt,.bak,.conf
```

Output:

```
joshitha@kali: ~  
File Actions Edit View Help  
  
(joshitha@kali)-[~]  
$ dirb http://192.168.56.102 -w /usr/share/wordlists/dirb/common.txt  
-----  
DIRB v2.22  
By The Dark Raver  
-----  
START_TIME: Tue Aug 13 19:50:31 2024  
URL_BASE: http://192.168.56.102/  
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt  
-----  
Scanning URL: http://192.168.56.102/  
-----  
+ http://192.168.56.102/index.php (CODE:200 | SIZE:319)  
+ http://192.168.56.102/robots.txt (CODE:200 | SIZE:24)  
+ http://192.168.56.102/server-status (CODE:403 | SIZE:278)  
-----  
END_TIME: Tue Aug 13 19:50:36 2024  
DOWNLOADED: 4612 - FOUND: 3  
  
(joshitha@kali)-[~]  
$ dirb http://192.168.56.102 -w /usr/share/wordlists/dirb/common.txt -x php,html,txt,bak,conf  
-----  
DIRB v2.22  
By The Dark Raver  
-----  
START_TIME: Tue Aug 13 19:50:48 2024  
URL_BASE: http://192.168.56.102/  
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt  
-----  
Scanning URL: http://192.168.56.102/  
-----  
+ http://192.168.56.102/index.php (CODE:200 | SIZE:319)  
+ http://192.168.56.102/config.php (CODE:200 | SIZE:512)  
+ http://192.168.56.102/login.html (CODE:200 | SIZE:1024)  
+ http://192.168.56.102/backup/ (CODE:301 | SIZE:178)  
-----  
END_TIME: Tue Aug 13 19:50:54 2024  
DOWNLOADED: 4612 - FOUND: 4  
  
(joshitha@kali)-[~]  
$
```